

Table 4: SMB-enum-users

Command/details	Explanation
<code>nmap --script smb-enum-users -iL IPList.txt -o smb-enum-users.txt</code>	To scan all hosts listed in <code>IPList.txt</code> for SMB users
Masked output of <code>smb-enum-users.txt</code>	
<pre>Nmap scan report for 192.168.1.109 Host is up (0.00015s latency). Not shown: 989 closed ports PORT STATE SERVICE 135/tcp open msrpc 139/tcp open netbios-ssn 445/tcp open microsoft-ds 1000/tcp open cadlock 1145/tcp open unknown 1720/tcp open H.323/Q.931 2401/tcp open cvsspserv 2967/tcp open symantec-av 5060/tcp open sip 5061/tcp open sip-tls 5101/tcp open admdog MAC Address: 00:XX:XX:XX:XX:04 (G-pro Computer)</pre>	Though the scan was performed on a live installation, to preserve confidentiality, the company name and user names are masked.
<pre>Host script results: smb-enum-users: TESTCOMPANYA-----y (RID: 1228) TESTCOMPANYaccounts_user (RID: 1125) TESTCOMPANYAdministrator (RID: 500) TESTCOMPANYa-----r (RID: 1168) TESTCOMPANYa-----g (RID: 1224) TESTCOMPANYa-----r (RID: 1122) TESTCOMPANYA-----D\$ (RID: 1249) TESTCOMPANYa-----e (RID: 1199) TESTCOMPANYA-----r (RID: 1231) TESTCOMPANYa-----e (RID: 1186) TESTCOMPANYA-----S\$ (RID: 1218) TESTCOMPANYA-----S2\$ (RID: 1227) TESTCOMPANYc-----r (RID: 1120) TESTCOMPANYc-----r (RID: 1120) TESTCOMPANYcvsspserv\$ (RID: 1176) TESTCOMPANYd-----e (RID: 1174) TESTCOMPANYd-----y (RID: 1212)</pre>	When the script result was shown to <code>TESTCOMPANY</code> management, they were shocked to see active accounts of many past employees! Suspending all further tests and network audits, they first disabled the unwanted accounts.



CAUTION!

While using NMap, be warned that under the stringent rules of the Indian Cyber law 2000, and its further amendments till date, even a port scan on a public IP could land you in jail. Do not scan computers that you do not own; and do not run scans over networks that you do not own, without written permission from the owners.

You may scan `scanme.nmap.org` for testing/learning, subject to conditions detailed in the NMap man page. Abuse of this service will be reported to the government by the site owners. You have been warned!

Use NMap very carefully, and only for discovery/audits of your own network. As mentioned earlier, it is a very powerful tool, and could cause disruption/damage to the target system or network. Fully understand what you are doing, especially with script scans, before you use them. Ignorance will not excuse anybody from being prosecuted under the law.

Also note that if you have a website of your own, either hosted with a provider, or on a rented physical server, the server and network do NOT belong to you even though you own the website's contents. You should ideally obtain permission from such hosting providers/server owners to carry out even testing probes of your own website.

SMB-enum-users

This is a very interesting script. In one go, you can identify all the users present on the entire network, and their status. You may wish to identify which of them have left the organisation, and disable/delete the corresponding account, as per company policy.

The power of NMap script scans doesn't end here. By using various scanning options, you can run combinations of various script categories (SMB scans, HTTP scans, etc) at one go. Please check the references for more details. 

References

- [1] Lua programming language: <http://lua.org/manual/>
- [2] Listing of NMap scripts: <http://nmap.org/nsedoc/>

By: Rajesh Deodhar

The author is a BE (Industrial Electronics), CISA (Certified Information Systems Auditor) and DCL (Diploma in Cyber Law). He has more than 15 years of experience in the field of computer hardware, networking, firewalls, and IS auditing as a director at Omega Systems and Services Pvt Ltd, Pune. You may send feedback/queries to him at rajesh@omegasystems.co.in.